

모의 침투 테스트 보고서

대상: HackTheBox — Cap, TwoMillion

작성일: 2026년 7월

차 례

1. 개요	3
2. 테스트 환경	3
3. Cap — 침투 테스트 결과	3
3.1 정보 수집	3
3.2 취약점 — IDOR	3
3.3 초기 침투	4
3.4 권한 상승 — Linux Capability	4
4. TwoMillion — 침투 테스트 결과	4
4.1 정보 수집	4
4.2 취약점 — API Broken Access Control	5
4.3 취약점 — Command Injection	5
4.4 초기 침투	5
4.5 권한 상승 — CVE-2023-0386	6
5. 취약점 종합 요약	6
6. 결론 및 권고사항	6

1. 개요

HackTheBox의 Cap, TwoMillion 머신에 대해 수행한 모의 침투 테스트 결과 보고서입니다. 주요정보통신기반시설 취약점 분석·평가 기준에 준하여 각 취약점의 현황, 대응 방안 및 대응 이유를 제시합니다.

2. 테스트 환경

항목	내용
공격 머신	Kali Linux (HackTheBox VPN 연결)
대상 머신	Cap (Linux, Easy), TwoMillion (Linux, Easy)
사용 도구	Nmap, Burp Suite, Wireshark, curl, netcat
점검 기준	주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

3. Cap — 침투 테스트 결과

3.1 정보 수집

항목	내용
포트 스캔 결과	21(FTP), 22(SSh), 80(HTTP) — 3개 포트 오픈
웹 서비스	네트워크 캡처 기능을 제공하는 대시보드 (Flask 기반)

3.2 취약점 — IDOR

항목	내용
분류	웹 애플리케이션 취약점
점검 항목	IDOR (Insecure Direct Object Reference)
점검 결과	취약
취약 경로	/data/{id}
취약 내용	URL의 id 값을 0으로 변경하여 다른 사용자의 PCAP 파일에 무단 접근 가능
확인 방법	/data/1 → /data/0 변경 후 타 사용자 캡처 파일 다운로드 확인
대응 방안	서버 측 소유권 검증 추가, PCAP 접근 시 세션 기반 권한 확인

▶ **대응 이유:** 사이트에서 자신의 네트워크 기록을 볼 때 주소창에 숫자가 있었습니다. 이 숫자를 1에서 0으로 바꿔 접속하자, 다른 사용자가 만든 네트워크 기록 파일이 다운로드되었습니다. 그 파일 안에는 해당 사용자가 파일 서버에 로그인할 때 사용한 아이디와 비밀번호가 그대로 적혀 있었습니다. 서버가 "이 파일이 내 것인지, 남의 것인지"를 확인하지 않았기 때문에 발생한 일입니다.

3.3 초기 침투

항목	내용
분류	자격증명 취약점
점검 항목	평문 전송 및 비밀번호 재사용
점검 결과	취약
취약 내용	FTP 자격증명이 암호화 없이 그대로 전송되며, 동일 비밀번호가 SSH에도 재사용됨
확인 방법	PCAP 분석으로 FTP 평문 비밀번호 확인 후 SSH 로그인 성공
대응 방안	FTP 대신 SFTP/FTPS 사용, 서비스별 독립적인 비밀번호 정책 수립
▶ 대응 이유: FTP로 파일을 전송할 때 아이디와 비밀번호가 암호화되지 않고 그대로 네트워크를 통해 흘러갑니다. 패킷을 가로챌 수 있는 위치에 있는 공격자가 이것을 보면 비밀번호가 그대로 보입니다. 더욱 심각한 것은 이 비밀번호를 서버 접속(SSH)에도 동일하게 사용해서, FTP 비밀번호 하나가 노출되자마자 서버 전체 접근 권한까지 획득할 수 있었습니다.	

3.4 권한 상승 — Linux Capability

항목	내용
분류	시스템 취약점
점검 항목	Linux Capability 남용
점검 결과	취약
취약 내용	python3.8에 cap_setuid가 설정되어 일반 사용자가 관리자(root) 권한으로 전환 가능
확인 방법	getcap -r / 2>/dev/null → cap_setuid 확인 → python3 코드로 root 쉘 획득
대응 방안	불필요한 capability 제거, 최소 권한 원칙 적용, 주기적 capability 감사
▶ 대응 이유: 일반 직원 권한으로 서버에 접속한 상태였습니다. Python 프로그램에 "관리자로 바꿀 수 있는 특별 권한"이 부여되어 있다는 것을 발견하고, 해당 프로그램을 실행하자 즉시 서버 최고 관리자 권한을 얻었습니다. 마치 일반 사원이 사장실 금고 열쇠가 담긴 서랍 열쇠를 갖고 있는 상황과 같습니다. 이 권한 하나로 서버의 모든 파일을 읽고, 수정하고, 삭제할 수 있게 됩니다.	

4. TwoMillion — 침투 테스트 결과

4.1 정보 수집

항목	내용
포트 스캔 결과	22(SSH), 80(HTTP) — 2개 포트 오픈
웹 서비스	HackTheBox 초기 버전 재현 사이트 (초대코드 기반, PHP)

4.2 취약점 — API Broken Access Control

항목	내용
분류	웹 애플리케이션 취약점
점검 항목	API Broken Access Control
점검 결과	취약
취약 경로	PUT /api/v1/admin/settings/update
취약 내용	일반 사용자가 {"is_admin":1} 파라미터 전송만으로 관리자 권한 획득 가능
확인 방법	PUT 요청에 is_admin:1 추가 전송 후 관리자 권한 확인
대응 방안	서버 측 역할 기반 권한 검증, 관리자 권한 변경 시 별도 승인 프로세스 적용
▶ 대응 이유: 로그인 후 서버와 주고받는 데이터를 확인해보니 "나는 관리자입니까?"를 묻는 항목 (is_admin)이 있었습니다. 이 값을 0에서 1로 바꿔 전송하자 서버가 아무 확인 없이 해당 계정을 관리자로 변경했습니다. 식당에서 손님이 스스로 "저는 VIP입니다"라고 써서 내밀었는데 직원이 확인도 없이 VIP 서비스를 제공하는 것과 같습니다. 이 관리자 권한으로 이후 서버 명령어 실행까지 이어졌습니다.	

4.3 취약점 — Command Injection

항목	내용
분류	웹 애플리케이션 취약점
점검 항목	OS Command Injection
점검 결과	취약
취약 경로	POST /api/v1/admin/vpn/generate
취약 내용	username 파라미터가 OS 명령어에 직접 삽입. 세미콜론(;)으로 임의 명령어 실행 가능
확인 방법	{"username":"test;id"} 전송 후 서버 계정 정보 응답 확인
대응 방안	입력값 화이트리스트 검증, shell 직접 실행 구조 제거 및 API 방식으로 전환
▶ 대응 이유: VPN 파일을 만드는 기능에서 사용자 이름 입력란에 이름 대신 명령어를 입력했습니다. 서버는 VPN을 만드는 동시에 그 명령어도 함께 실행했고, 응답으로 서버의 현재 실행 계정 정보가 돌아왔습니다. 이후 "공격자 컴퓨터로 접속해"라는 명령어를 넣자 서버가 스스로 공격자 컴퓨터에 연결해왔습니다. 웹 입력란 하나가 서버를 원격으로 조종할 수 있는 리모컨이 된 상황입니다.	

4.4 초기 침투

항목	내용
분류	자격증명 취약점
점검 항목	평문 자격증명 저장 및 재사용
점검 결과	취약
취약 내용	.env 파일에 DB 비밀번호가 평문 저장, SSH 계정에도 동일 비밀번호 재사용
확인 방법	cat /var/www/html/.env 로 비밀번호 확인 후 SSH 로그인 성공
대응 방안	환경 변수 파일 접근 권한 제한, 서비스별 독립 자격증명, 시크릿 관리 솔루션 도입
▶ 대응 이유: 리버스셸로 서버에 접속한 뒤 웹 소스 폴더를 탐색하다 설정 파일(.env)을 발견했습니다. 파일을 열었더니 데이터베이스 접속 비밀번호가 메모장처럼 그대로 적혀 있었습니다. 이 비밀번호를 서버 접속(SSH)에 그대로 입력해봤더니 로그인이 되었습니다. 하나의 비밀번호를 여러 서비스에 동시에 사용하면, 그 비밀번호 하나가 노출되는 순간 모든 서비스의 문이 한꺼번에 열리게 됩니다.	

4.5 권한 상승 — CVE-2023-0386

항목	내용
분류	시스템 취약점
점검 항목	Linux 커널 취약점 (CVE-2023-0386)
점검 결과	취약
취약 내용	Linux OverlayFS의 결함으로 일반 사용자가 관리자(root) 권한 획득 가능
확인 방법	CVE-2023-0386 공개 PoC(exp.sh) 실행 후 root 쉘 획득
대응 방안	커널 버전 업데이트, OverlayFS 미사용 시 비활성화, 비특권 네임스페이스 제한
▶ 대응 이유: 서버 운영체제에 이미 알려진 보안 결함이 있었습니다. 인터넷에 공개된 공격 도구를 다운로드해서 실행하자, 10초도 걸리지 않아 서버 최고 관리자 권한을 얻었습니다. 복잡한 해킹 기술이 필요한 것이 아니라, 프로그램 하나를 실행하는 것만으로 서버 전체를 장악할 수 있는 상황입니다. 운영체제를 최신 버전으로 유지하지 않으면 인터넷에 공개된 공격 도구만으로도 언제든지 뚫릴 수 있습니다.	

5. 취약점 종합 요약

머신	취약점	설명	점검결과	비고
Cap	IDOR	PCAP 무단 접근 → 자격증명 탈취	취약	즉시 조치
Cap	Linux Capability	cap_setuid → root 획득	취약	즉시 조치
TwoMillion	API BAC	관리자 권한 무단 획득	취약	즉시 조치
TwoMillion	Command Injection	RCE → 리버스셸	취약	즉시 조치
TwoMillion	CVE-2023-0386	OverlayFS → root 획득	취약	커널 패치

6. 결론 및 권고사항

두 머신에서 발견된 모든 취약점은 서버 장악 수준의 위협으로, 비밀번호 재사용이 두 머신 모두에서 초기 침투의 핵심 요인이었습니다.

즉각 조치 권고: ① 서버 측 권한 검증 강화, ② 암호화 통신 프로토콜 적용, ③ 서비스별 독립 자격증명 정책, ④ 커널 및 시스템 최신 패치 적용, ⑤ 최소 권한 원칙(PoLP) 기반 운영